

VULNERABILITY ASSESSMENT REPORT

OWASP Juice Shop — Web Application Security Audit

Target Application	OWASP Juice Shop
Target URL	http://juice-shop.herokuapp.com
IP Address	54.220.192.176 (AWS EU-West-1)
Assessment Date	June 2, 2026
Assessor	Sourabh
Internship	Future Interns — Cyber Security Track
Task	Task 1 — Vulnerability Assessment
Classification	Confidential

■ High	■ Medium	■ Low	■ Info	Total
2	4	4	3	13

This report was prepared for educational purposes as part of the Future Interns Cyber Security Internship Program. All testing conducted legally on an intentionally vulnerable application.

1. EXECUTIVE SUMMARY

A comprehensive vulnerability assessment was performed on the OWASP Juice Shop web application using industry-standard tools including Nmap, OWASP ZAP, and Browser DevTools. The assessment identified **13 vulnerabilities** across multiple risk categories, including 2 high-severity issues that require immediate attention.

Scope & Target

Field	Details
Target	OWASP Juice Shop
URL	http://juice-shop.herokuapp.com
IP Address	54.220.192.176
Infrastructure	Amazon AWS EC2 (EU-West-1 / Heroku)
Assessment Type	Passive + Active Vulnerability Scan
Date	June 2, 2026
Tools	Nmap 7.99 OWASP ZAP 2.17.0 Browser DevTools

Risk Summary

Risk Level	Count	Description
HIGH	2	Immediate action required — direct business impact
MEDIUM	4	Should be remediated in next development cycle
LOW	4	Best practice improvements recommended
INFO	3	Informational findings for awareness
TOTAL	13	Total vulnerabilities identified

2. METHODOLOGY & TOOLS

The assessment followed a structured passive and active scanning methodology using three complementary tools to ensure comprehensive coverage of potential vulnerabilities.

Tool	Version	Purpose	Type
Nmap	7.99	Port scanning, service & version detection, OS fingerprinting	Active
OWASP ZAP	2.17.0	Automated web app vulnerability scanning, spider crawl, active attack	Active
Browser DevTools	Chrome	Manual analysis of HTTP headers, cookies, and client-side security	Passive
Canva	-	Professional report design and presentation	Reporting

Assessment Steps

Step 1 — Reconnaissance

Nmap scan on juice-shop.herokuapp.com to identify open ports, running services, server technology, and SSL certificate details.

Step 2 — Automated Scan

OWASP ZAP Automated Scan (Default Policy) launched against the target. Spider crawled 157 endpoints, made 6,106 requests, and identified 13 alerts.

Step 3 — Manual Analysis

Browser DevTools used to manually inspect HTTP response headers, identify missing security headers, and audit cookie security flags.

Step 4 — Analysis & Classification

All findings classified by risk level (High/Medium/Low/Info) with CWE references and business impact descriptions.

Step 5 — Reporting

Findings documented with evidence screenshots, remediation steps, and professional report design.

3. NMAP SCAN FINDINGS

Nmap 7.99 was used to perform a comprehensive port scan with service version detection (-sV) and default script scanning (-sC) on juice-shop.herokuapp.com.

Open Ports & Services

Port	State	Service	Version / Notes
80/tcp	OPEN	HTTP	heroku-router — OWASP Juice Shop
443/tcp	OPEN	HTTPS/SSL	heroku-router — TLS, cert valid to 2027-01-29
2000/tcp	OPEN	cisco-sccp?	Unrecognized service — potential information disclosure

Additional Findings

Finding	Detail	Risk
FTP Directory Exposed	/ftp listed as disallowed in robots.txt but potentially accessible	Medium
CORS Headers Present	HEAD GET POST PUT DELETE PATCH methods all allowed	Medium
Server Technology Disclosed	Server: Heroku / heroku-router (information disclosure)	Low
Unrecognized Service	Port 2000/tcp running unknown cisco-sccp service	Low
SSL Certificate	Valid wildcard cert *.herokuapp.com, expires 2027-01-29	Info
Cloud Infrastructure	Hosted on AWS EC2 EU-West-1 (ec2-54-220-192-176)	Info

4. HIGH RISK FINDINGS

■ FINDING 1 — SQL INJECTION (SQLite)

Attribute	Detail
Risk Level	HIGH
CWE	CWE-89 — Improper Neutralization of Special Elements in SQL Commands
WASC ID	WASC-19
URL	http://juice-shop.herokuapp.com/rest/products/search?q=%27%28
Parameter	q (search query)
Attack	Injected payload: '(
Evidence	Response contained: SQLITE_ERROR
Impact	Attacker can read, modify, or delete database records. Full DB compromise possible.
Fix	Use parameterized queries / prepared statements. Never concatenate user input into SQL.

■ FINDING 2 — PII DISCLOSURE (Credit Card Data)

Attribute	Detail
Risk Level	HIGH
CWE	CWE-359 — Exposure of Private Personal Information to Unauthorized Actor
WASC ID	WASC-13
URL	https://firefox.settings.services.mozilla.com/...crash-reports-ondemand/changeset
Evidence 1	Credit Card: VISA — BIN: 406507 — Number: 4065075501014
Evidence 2	Credit Card: MAESTRO — BIN: 676392 — Number: 676392874399
Impact	Exposure of financial PII (credit card numbers) violates PCI-DSS and GDPR regulations.
Fix	Audit all API responses. Never expose PII in responses. Implement data masking.

5. MEDIUM RISK FINDINGS

■ FINDING 1 — CSP Header Not Set

Attribute	Detail
Risk Level	MEDIUM
CWE / WASC	CWE-693 WASC-15
Description	Content-Security-Policy header missing on all pages.
Business Impact	Enables XSS and data injection attacks.
Remediation	Add Content-Security-Policy header to all HTTP responses.

■ FINDING 2 — Cross-Domain Misconfiguration (CORS)

Attribute	Detail
Risk Level	MEDIUM
CWE / WASC	CWE-264 WASC-14
Description	Access-Control-Allow-Origin: * found on multiple endpoints.
Business Impact	Allows any external domain to read API responses — data theft risk.
Remediation	Restrict Access-Control-Allow-Origin to specific trusted domains.

■ FINDING 3 — Missing Anti-Clickjacking Header

Attribute	Detail
Risk Level	MEDIUM
CWE / WASC	CWE-1021 WASC-15
Description	X-Frame-Options / CSP frame-ancestors not set on socket.io endpoints.
Business Impact	Application can be embedded in malicious iframes (clickjacking attacks).
Remediation	Add X-Frame-Options: DENY or SAMEORIGIN to all responses.

■ FINDING 4 — Session ID in URL Rewrite

Attribute	Detail
Risk Level	MEDIUM
CWE / WASC	CWE-598 WASC-13
Description	Session ID exposed in URL: sid=0W06G41HqMX9Lhr5AHfX
Business Impact	Session ID leaked via Referer headers, browser history, and server logs.
Remediation	Store session IDs in HttpOnly cookies, never in URLs.

■ FINDING 5 — Insecure Cookies (Missing Flags)

Attribute	Detail
Risk Level	MEDIUM
CWE / WASC	CWE-614 WASC-13

Description	Cookies language and welcomebanner_status missing HttpOnly, Secure, SameSite flags.
Business Impact	Cookies vulnerable to XSS theft, CSRF attacks, and interception over HTTP.
Remediation	Set HttpOnly, Secure, and SameSite=Strict flags on all cookies.

6. LOW RISK FINDINGS

#	Vulnerability	CWE	Description	Fix
L1	Application Error Disclosure	CWE-550	HTTP 500 error reveals internal file paths and stack traces	Implement custom error pages. Log errors separately.
L2	Private IP Disclosure	CWE-497	Internal IP 192.168.99.100:3000 exposed in API response	Remove internal IPs from all HTTP responses.
L3	Timestamp Disclosure	CWE-497	Unix timestamps exposed — reveals server time and deployment time	Disable timestamps; avoid exposing sensitive information.
L4	X-Content-Type-Options Missing	CWE-693	nosniff header missing on 4 endpoints — MIME sniffing possible	Set X-Content-Type-Options: nosniff on all responses.

7. DEVTOOLS — SECURITY HEADERS ANALYSIS

Security Header	Value Found	Status	Risk
Content-Security-Policy	NOT PRESENT	MISSING	Medium
Strict-Transport-Security	NOT PRESENT	MISSING	Medium
Access-Control-Allow-Origin	*	MISCONFIGURED	Medium
X-Frame-Options	SAMEORIGIN	Present	OK
X-Content-Type-Options	nosniff	Present	OK
Feature-Policy	payment 'self'	Partial	Low
Cache-Control	public, max-age=0	Weak	Low

8. REMEDIATION SUMMARY

Priority	Vulnerability	Risk	Recommended Fix
P1	SQL Injection	HIGH	Use parameterized queries. Never concatenate user input into SQL strings.
P2	PII Disclosure	HIGH	Audit all API responses. Implement data masking for sensitive fields.
P3	CSP Header Missing	MEDIUM	Add Content-Security-Policy: default-src 'self' to all responses.
P4	CORS Misconfiguration	MEDIUM	Replace * with specific trusted origins in Access-Control-Allow-Origin.
P5	Insecure Cookies	MEDIUM	Set HttpOnly; Secure; SameSite=Strict flags on all application cookies.
P6	Missing Anti-Clickjacking	MEDIUM	Add X-Frame-Options: SAMEORIGIN or CSP frame-ancestors directive.
P7	Session ID in URL	MEDIUM	Store session tokens in HttpOnly cookies only, never in URLs.
P8	FTP Directory Exposed	MEDIUM	Restrict /ftp directory access. Implement proper authentication.
P9	Error Disclosure	LOW	Implement custom error pages. Log errors server-side, not in responses.
P10	Private IP Disclosure	LOW	Remove all internal IP addresses from HTTP response bodies and configs.

9. CONCLUSION

The vulnerability assessment of the OWASP Juice Shop identified **13 security issues** across all risk levels. The two high-severity findings — SQL Injection and PII Disclosure — require immediate remediation as they pose a direct risk to data integrity and user privacy.

The medium-severity findings, particularly the missing Content Security Policy header, CORS misconfiguration, and insecure cookie configurations, should be addressed in the next development cycle to significantly reduce the application's attack surface.

Skills Gained During This Assessment	
Vulnerability Analysis & Risk Classification Web Application Security Testing (OWASP Top 10) Network Scanning & Enumeration with Nmap Automated Scanning with OWASP ZAP Security Headers & Cookie Analysis with DevTools Professional Security Reporting	

Report Prepared By	Details
Name	Sourabh
Role	Cyber Security Intern
Organization	Future Interns
Track	Cyber Security
Task	Task 1 — Vulnerability Assessment Report
Date	June 2, 2026
Repository	github.com/[Your-Username]/FUTURE_CS_01

DISCLAIMER: This assessment was conducted on an intentionally vulnerable application (OWASP Juice Shop) for educational purposes only. All testing was performed legally and ethically as part of the Future Interns Cyber Security Internship Program.